

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

GraphQL Introspection and Schema Discovery Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	GraphQL introspection
Result Type	Schema discovery
Evidence Report File	16-graphql-introspection-schema-discovery-evidence-report.pdf
Testing Phase	GraphQL Schema Enumeration
Tool / Component	GraphQL Query / DVGA
OWASP / Security Mapping	API9:2023 Improper Inventory Management / GraphQL Schema Exposure
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

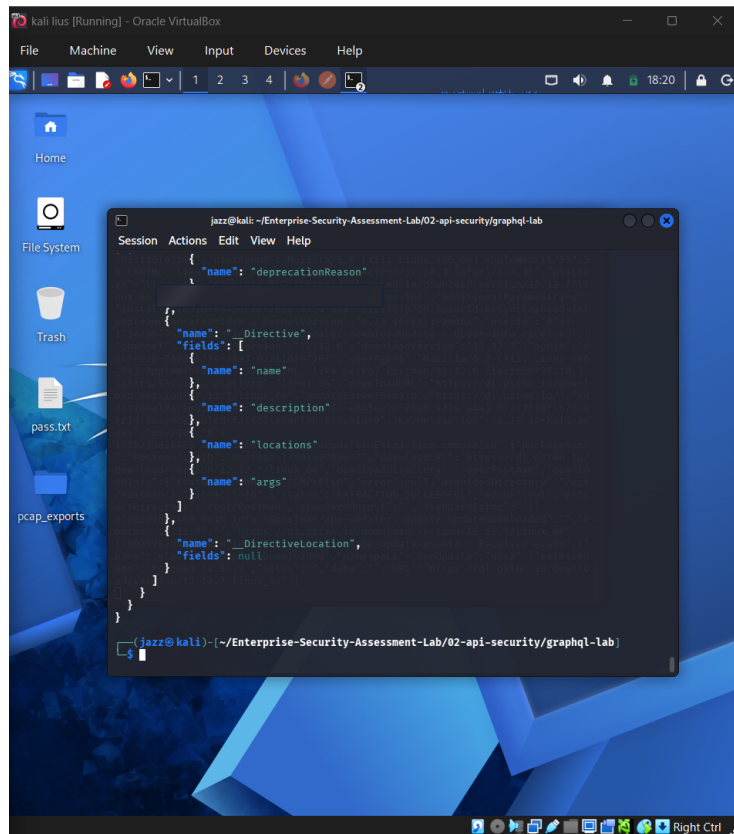


Figure 1 - Embedded screenshot evidence for: GraphQL introspection

What this evidence proves

The evidence shows GraphQL introspection/schema output. This confirms that schema information was available during testing.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	GraphQL Schema Enumeration
Tool / Component	GraphQL Query / DVGA
Assessment Objective	Test whether GraphQL introspection is enabled and whether the schema can be discovered by a client.
Result Type	Schema discovery
OWASP / Security Mapping	API9:2023 Improper Inventory Management / GraphQL Schema Exposure

Why this evidence matters

Introspection can be useful for development but risky in production because it exposes available types, fields, queries, mutations, and relationships.

Command / workflow used

```
Send introspection query
Review returned schema types
Identify queries, mutations, fields, and object relationships
Map interesting data paths for authorization review
```

Sanitized output style

```
Introspection query returned schema information
Types and fields reviewed
Sensitive schema details documented only at high level
```

3. Professional Interpretation

This evidence row should be interpreted as: **Schema discovery**.

Exposed introspection can help attackers rapidly understand the API structure and identify sensitive queries or mutations to target.

Assessor notes

If this is a lab, schema exposure is expected but still useful as a learning artifact.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

Exposed introspection can help attackers rapidly understand the API structure and identify sensitive queries or mutations to target.

Recommended remediation / hardening actions

- Disable introspection in production if not required.
- Require authentication for GraphQL tooling.
- Protect every resolver with authorization.
- Limit query depth and complexity.
- Avoid verbose error messages.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Detailed schema fields if sensitive.
- User data returned in examples.
- Hostnames and tokens.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[GraphQL introspection](./reports/evidence/16-graphql-introspection-schema-discovery-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.